

Section 09

Industrial Security (Bachelor)



Section 09 – Standards, Compliance, Governance

Standards, Compliance, and Governance

Lecture Notes

Department of Computer Science

2026-05-18

Industrial Security (Bachelor)

Section 09

Industrial Security (Bachelor)



Section 09 – Standards, Compliance, Governance

Standards, Compliance, and Governance
Lecture Notes
Department of Computer Science

- 1 Standards
- 2 Regulations
- 3 Programme

By the end of this section you will be able to

- Navigate the IEC 62443 family of standards.
- Understand the role of NIST CSF and NIST SP 800-82.
- Recognise major regulations: NIS2, KRITIS, NERC CIP, TSA, CIRCIA.
- Sketch the structure of an OT security programme.

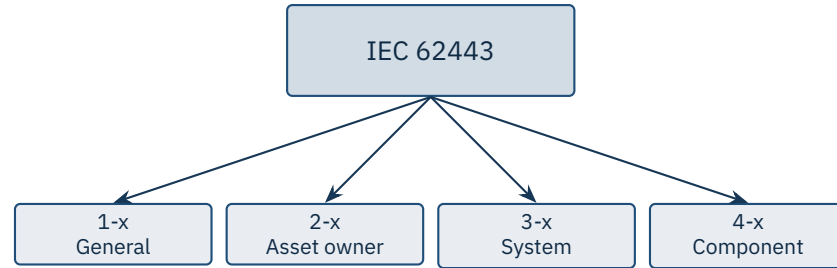
└ Learning Objectives

By the end of this section you will be able to

- Navigate the IEC 62443 family of standards.
- Understand the role of NIST CSF and NIST SP 800-82.
- Recognise major regulations: NIS2, KRITIS, NERC CIP, TSA, CIRCIA.
- Sketch the structure of an OT security programme.

1

Standards

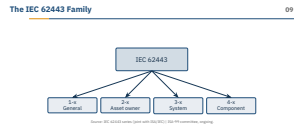


Source: IEC 62443 series (joint with ISA/IEC) | ISA-99 committee, ongoing.

2026-05-18

Industrial Security (Bachelor)
└ Standards

└ The IEC 62443 Family



IEC 62443 is the gold standard for industrial automation security and the only family written specifically for OT, but *no plant on the planet is fully compliant with all 14+ parts*. The split is the load-bearing idea: 1-x concepts, 2-x for the asset owner (the utility, the factory), 3-x for the system integrator, 4-x for the component vendor (the PLC, the HMI). Use this to push back on vendor marketing: a PLC cannot be *62443 compliant* on its own — it can only be *62443-4-2 certified*. Ask the class: if you are the operator of a wastewater plant, which parts are *your* legal and contractual responsibility?

SL 1	Casual / coincidental violation
SL 2	Simple, low-resource attacker
SL 3	Sophisticated, moderate resources
SL 4	Sophisticated, nation-state

Per-zone target

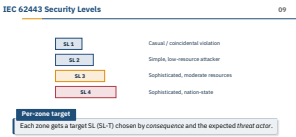
Each zone gets a target SL (SL-T) chosen by *consequence* and the expected *threat actor*.

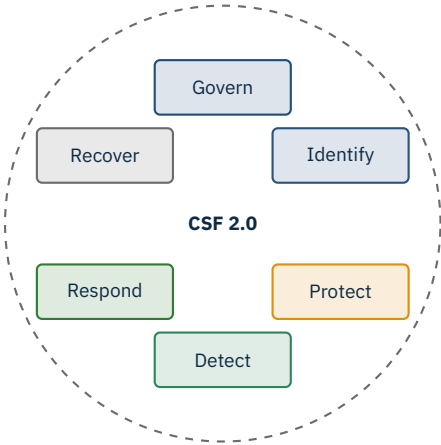
2026-05-18

Industrial Security (Bachelor)
└ Standards

└ IEC 62443 Security Levels

The SL scale is an *attacker model*, not a feature checklist — this is the single most-misunderstood part of 62443. SL1 is accidental misuse (an engineer who fat-fingers something), SL2 is a casual attacker with low resources, SL3 is a sophisticated actor with moderate resources, SL4 is a well-funded nation-state. Pre-empt the cynicism: SL3 is *not* achievable everywhere — for most legacy brownfield plants, SL2 is the realistic ceiling because the field devices simply cannot enforce strong authentication or cryptographic integrity. The per-zone SL-T is chosen from consequence (what happens if it fails?) plus expected threat actor. Ask: is your office printer SL1 or SL2? What about the safety PLC on a hydrogen line?





Outcome-based, sector-neutral. NIST SP 800-82 Rev. 3 is the ICS-specific companion.

Source: NIST, *Cybersecurity Framework 2.0*, Feb 2024 | NIST SP 800-82 Rev. 3, Sep 2023.

2026-05-18

Industrial Security (Bachelor)

└ Standards

└ NIST Cybersecurity Framework

CSF 2.0 added *Govern* as a sixth function in February 2024 — before that, governance was buried inside *Identify*, which let boards pretend it was an IT problem. The CSF is outcome-based and sector-neutral: it tells you *what* to achieve, not *how*. NIST SP 800-82 Rev. 3 (September 2023) is the OT-specific companion that maps CSF outcomes to ICS realities — e.g., *Detect* on a serial Modbus link does not look like *Detect* on an enterprise LAN. Common pairing in industry: CSF for the board slides, 62443 for the engineering work, 800-82 to translate between them.

NIST Cybersecurity Framework09

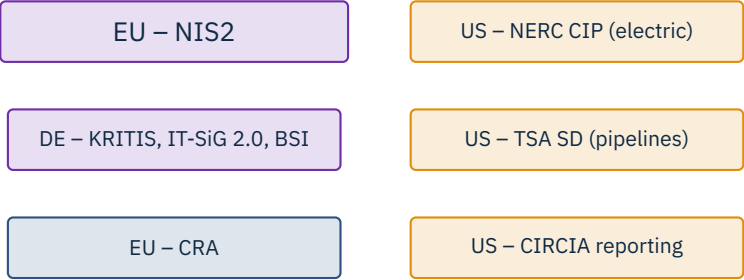


CSF 2.0

Outcome-based, sector-neutral. NIST SP 800-82 Rev. 3 is the ICS-specific companion.
Source: NIST, *Cybersecurity Framework 2.0*, Feb 2024 | NIST SP 800-82 Rev. 3, Sep 2023.

2

Regulations



Sector: IEC 62443, IEC 61850, ANSI/ISA-84

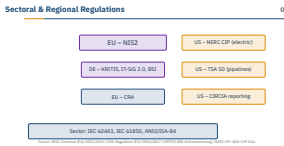
Source: NIS2: Directive (EU) 2022/2555 | CRA: Regulation (EU) 2024/2847 | KRITIS: BSI-Kritisverordnung | NERC CIP-002–CIP-014.

2026-05-18

Industrial Security (Bachelor)
└ Regulations

└ Sectoral & Regional Regulations

Two dates students should memorise: NIS2 (Directive (EU) 2022/2555) transposition dead-line was 17 October 2024 — most member states missed it, but the duties apply anyway. The CRA (Regulation (EU) 2024/2847) was signed 23 October 2024 and most provisions enter force on 11 December 2027, with vulnerability-reporting duties biting earlier. KRITIS has had real teeth in Germany since 2015 via the IT-Sicherheitsgesetz and the BSI-Kritisverordnung; thresholds dropped significantly under IT-SiG 2.0. On the US side, NERC CIP (CIP-002 through CIP-014) is the only mandatory cyber regime with multi-million-dollar fines per violation per day — the electric sector takes it seriously. Transition cue: *your factory in Stuttgart making car parts — which of these apply?* Answer: probably not KRITIS (below thresholds), maybe NIS2 (manufacturing of motor vehicles is an Annex II *important entity* sector), definitely CRA the moment you ship a connected product.



3

Programme

- 1. Governance – charter, RACI, executive sponsor
- 2. Asset inventory – ground truth
- 3. Risk assessment – IEC 62443-3-2
- 4. Architecture – zones, conduits, segmentation
- 5. Controls – baseline per SL-T
- 6. Operations – patching, monitoring, IR
- 7. Training & awareness – engineers and IT
- 8. Measurement – KPIs, audits, lessons learned

2026-05-18

Industrial Security (Bachelor)
└ Programme
└ Building an OT Security Programme

This is the operational shape of any 62443-2-1 programme. The order matters: governance first, because without an executive sponsor the rest dies in a budget review; asset inventory second, because you cannot protect what you do not know exists — and most operators discover 20–40% more devices than they expected on day one. Risk assessment per 62443-3-2 produces the zones, conduits, and SL-Ts that drive every downstream decision. Pre-empt the cynicism here too: *compliance is not security* — but skipping any of these eight rows is exactly how breaches happen. Ask: in a 200-person engineering plant, who actually owns step 1?

Building an OT Security Programme

1. Governance – charter, RACI, executive sponsor
2. Asset inventory – ground truth
3. Risk assessment – IEC 62443-3-2
4. Architecture – zones, conduits, segmentation
5. Controls – baseline per SL-T
6. Operations – patching, monitoring, IR
7. Training & awareness – engineers and IT
8. Measurement – KPIs, audits, lessons learned

- Cybersecurity management system (CSMS) – the OT-side ISMS
- Risk analysis, system architecture, security policies
- Patch management, incident response, training
- Supplier requirements (62443-2-4) and SDL (62443-4-1)

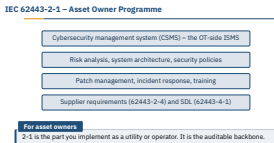
For asset owners
2-1 is the part you implement as a utility or operator. It is the auditable backbone.

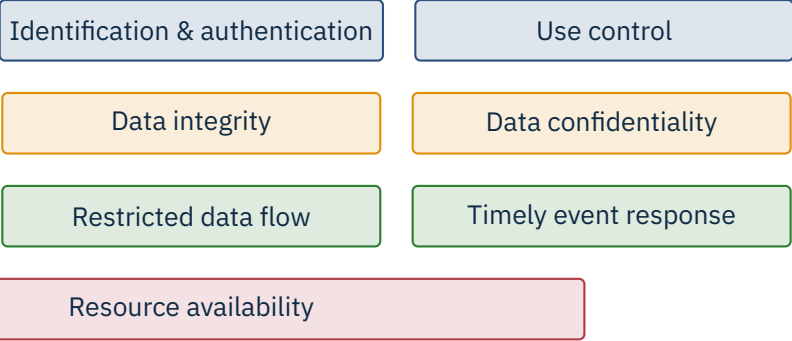
2026-05-18

Industrial Security (Bachelor)
└ Programme

└ IEC 62443-2-1 – Asset Owner Programme

62443-2-1 is the OT-side equivalent of ISO/IEC 27001 – a cybersecurity management system (CSMS) with policies, processes, and evidence. If your customer asks *are you 62443 compliant?* as an operator, what they really want to see is a 2-1 conformance statement plus your 3-2 risk assessment. The supplier requirements in 62443-2-4 are how you push security duties down your supply chain – in EU contracts post-NIS2, this is increasingly contractual rather than optional. 4-1 (the secure development lifecycle) is the vendor mirror: SBOM, threat modelling, vulnerability handling. Note that 2-1 was substantially revised in 2024 to align with NIS2 and the CRA’s vendor duties.





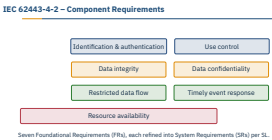
Seven Foundational Requirements (FRs), each refined into System Requirements (SRs) per SL.

2026-05-18

Industrial Security (Bachelor)
└ Programme

└ IEC 62443-4-2 – Component Requirements

These seven Foundational Requirements (FRs) are the universal vocabulary of OT security — once you internalise them, every vendor datasheet starts to make sense. Each FR breaks into Component Requirements (CRs) and System Requirements (SRs), and each requirement is repeated at SL1, SL2, SL3, SL4 with increasing rigor. Example: *Identification & authentication* at SL1 might mean shared passwords, at SL2 unique users, at SL3 multi-factor, at SL4 cryptographically bound hardware tokens. Resource availability is the odd one out — it is the FR most directly tied to safety and the one IT security people consistently underestimate. When you certify a PLC, you certify it *against a specific SL across these seven FRs* — often SL2-capable for most FRs, SL1 for one or two stragglers.



- ICS-specific companion to NIST SP 800-53.
- Published 2023; mapping tables to IEC 62443 included.
- Tiered guidance: low / moderate / high impact systems.
- Strong focus on **safety** and **operational continuity** – not just confidentiality.

When to reach for it

US federal contractors, sector-CISA regulated entities, and any team that prefers outcome-based controls to a prescriptive standard.

2026-05-18

Industrial Security (Bachelor)
└ Programme

└ NIST SP 800-82 Rev. 3

SP 800-82 Rev. 3 (September 2023) is the long-awaited rewrite that finally brings ICS guidance in line with the modern threat landscape — it has explicit chapters on cloud-connected OT, 5G, and zero-trust patterns. The mapping tables to 62443 are gold: they let a US team that lives in NIST-land talk to a European partner that lives in IEC-land without translating from scratch. The safety-first framing is the genuine differentiator from IT security guidance — it accepts that you cannot simply reboot a turbine to apply a patch. Reach for 800-82 when you want *outcomes with examples* rather than the more bureaucratic 62443 conformance language.

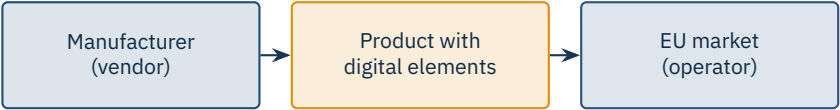
NIST SP 800-82 Rev. 3

09

- ICS-specific companion to NIST SP 800-53.
- Published 2023; mapping tables to IEC 62443 included.
- Tiered guidance: low / moderate / high impact systems.
- Strong focus on **safety** and **operational continuity** – not just confidentiality.

When to reach for it

US federal contractors, sector-CISA regulated entities, and any team that prefers outcome-based controls to a prescriptive standard.



New duties

Manufacturers must provide security updates, vulnerability handling, and an SBOM. CE marking now covers cybersecurity too.

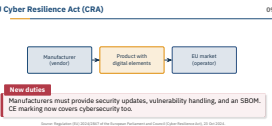
Source: Regulation (EU) 2024/2847 of the European Parliament and Council (Cyber Resilience Act), 23 Oct 2024.

2026-05-18

Industrial Security (Bachelor)
└ Programme

└ EU Cyber Resilience Act (CRA)

The CRA is the EU’s answer to *ship-and-forget* vendors: any *product with digital elements* placed on the EU market — a PLC, a router, a smart sensor, even a software library — now carries lifetime cybersecurity duties. Manufacturers must provide security updates for the expected product lifetime (default 5 years), publish an SBOM, run a coordinated vulnerability disclosure process, and report actively exploited vulnerabilities to ENISA within 24 hours. CE marking now legally covers cybersecurity, which means market surveillance authorities can pull non-compliant products from shelves. Most provisions enter force 11 December 2027; vulnerability-reporting duties bite earlier in September 2026. For OT vendors this is genuinely transformational — the days of selling a PLC with a 15-year support tail and no patches are over.



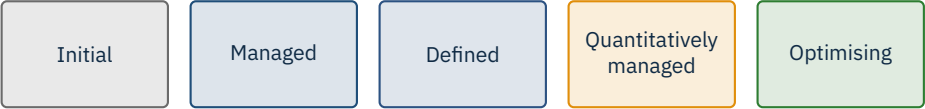
- Risk-based, sector-tailored controls (energy, transport, water).
- Strong emphasis on *supply chain* obligations.
- Continuous monitoring (network + endpoint) for OT estates.
- Cross-border incident-information-sharing framework.

For EU operators

ENISA guidance is non-binding but shapes how national CERTs read NIS2 duties.

ENISA OT Recommendations

ENISA does not regulate but it heavily influences — the *Good practices for the security of IACS* series (2020 onwards) is the de-facto reference national CERTs and CSIRTs cite when interpreting NIS2 *appropriate measures*. The supply-chain emphasis matches CRA's manufacturer duties: an operator is now expected to demand SBOM and vulnerability-handling evidence from suppliers and to record it. Continuous monitoring as ENISA defines it is broader than IDS — it includes asset-discovery delta tracking, configuration drift, and behavioural anomaly detection on OT protocols (Modbus, S7, DNP3). The cross-border framework matters because incidents in OT often span jurisdictions — a water-utility breach in Bavaria can quickly become a federal and EU-level reporting event under NIS2 Article 23.



Common references: **C2M2** (DOE), **CMMC** (US DoD), and IEC 62443's own programme maturity.

Maturity models answer a different question than control frameworks: not *do you do X?* but *how reliably and repeatably do you do X?*. C2M2 (the US Department of Energy's Cybersecurity Capability Maturity Model) is the most-used one in critical-infrastructure self-assessments — it is free, self-administered, and produces a defensible heatmap. CMMC is the US Department of Defense version with mandatory third-party certification for contractors. Most plants land at Managed (level 1) or Defined (level 2); reaching Quantitatively Managed requires real telemetry on security KPIs that very few OT teams have. The honest message to engineering teams: aim for level 2 with evidence rather than level 3 with hand-waving — auditors and incident responders will both appreciate the difference.

- Up-to-date asset inventory with firmware versions
- Documented zones & conduits (preferably in a CMDB)
- Risk register with named owners and review dates
- Patch and change-management records
- Backup logs with restore-test evidence
- Incident-response playbooks plus a recent tabletop report
- Training attendance for operators and engineers

Tip

The first audit is hardest. Treat it as a baseline scan – gaps you find are not failures, they are your roadmap.

2026-05-18

Industrial Security (Bachelor) └ Programme

└ Audit Preparation Checklist

This list is what a NIS2 supervisory authority, a NERC CIP auditor, or a 62443-2-1 assessor will actually ask to see — in roughly this order. The most common failure modes: an asset inventory that is six months stale, zones-and-conduits that exist on a PowerPoint slide but not in a CMDB, and backup logs without restore-test evidence (a backup you have never restored is a wish, not a backup). The tabletop report is often the cheapest single artefact to produce and the one that most impresses auditors — two hours of structured discussion with operators creates more security uplift than a quarter of patching. Emphasise the tip: the first audit is a baseline, not a verdict — the regulator's job is partly to help you produce a credible roadmap.

- Up-to-date asset inventory with firmware versions
- Documented zones & conduits (preferably in a CMDB)
- Risk register with named owners and review dates
- Patch and change-management records
- Backup logs with restore-test evidence
- Incident-response playbooks plus a recent tabletop report
- Training attendance for operators and engineers

Tip

The first audit is hardest. Treat it as a baseline scan – gaps you find are not failures, they are your roadmap.

★ Key Takeaway: What to remember from this section

- IEC 62443 provides the engineering vocabulary; NIST CSF gives the outcomes language.
- Security Levels (SL 1–4) tie risk to required control rigor.
- Regulations now demand board-level accountability and incident reporting.
- A programme is governance, inventory, risk, architecture, controls, ops, training, measurement.

The four take-aways are the absolute minimum a graduate of this lecture should be able to recite at a job interview. If a candidate cannot distinguish the engineering vocabulary (62443 zones, conduits, SLs) from the outcomes vocabulary (CSF Govern–Identify–Protect–Detect–Respond–Recover), they will struggle in any cross-functional OT security role. Reinforce the single most important industry truism one more time: *compliance is not security*, but every breach post-mortem of the last decade reads like a list of skipped 62443 foundational requirements. Post-NIS2 and post-CRA, board-level accountability and 24-hour incident reporting are no longer optional — treat them as design constraints from day one. Final transition: next section we move from *what should we do?* into *how do we actually defend a live process?*

- IEC 62443 series. *Industrial communication networks – IT security for networks and systems* (joint ISA/IEC).
- NIST. *Cybersecurity Framework 2.0*, Feb 2024.
- Stouffer, K. et al. *NIST SP 800-82 Rev. 3 – Guide to OT Security*, Sep 2023.
- NIST SP 800-53 Rev. 5. *Security and Privacy Controls for Information Systems and Organizations*, 2020.
- Directive (EU) 2022/2555. *NIS2 Directive*, 14 Dec 2022.
- Regulation (EU) 2024/2847. *Cyber Resilience Act*, 23 Oct 2024.
- Germany BSI. *BSI-Kritisverordnung (BSI-KritisV) and IT-Sicherheitsgesetz 2.0*.
- ENISA. *Good practices for the security of IACS*, 2020 onwards.
- NERC. *CIP Reliability Standards*, CIP-002 through CIP-014.
- US TSA. *Pipeline / Rail Security Directives*, 2021 onwards.
- US CISA. *CIRCA – Cyber Incident Reporting for Critical Infrastructure Act*, in rule-making.
- DOE. *Cybersecurity Capability Maturity Model (C2M2)*, current.

2026-05-18

Industrial Security (Bachelor)
└ Programme

└ References – Section 09

- IEC 62443 series. *Industrial communication networks – IT security for networks and systems* (joint ISA/IEC).
- NIST. *Cybersecurity Framework 2.0*, Feb 2024.
- Stouffer, K. et al. *NIST SP 800-82 Rev. 3 – Guide to OT Security*, Sep 2023.
- NIST SP 800-53 Rev. 5. *Security and Privacy Controls for Information Systems and Organizations*, 2020.
- Directive (EU) 2022/2555. *NIS2 Directive*, 14 Dec 2022.
- Regulation (EU) 2024/2847. *Cyber Resilience Act*, 23 Oct 2024.
- Germany BSI. *BSI-Kritisverordnung (BSI-KritisV) and IT-Sicherheitsgesetz 2.0*.
- ENISA. *Good practices for the security of IACS*, 2020 onwards.
- NERC. *CIP Reliability Standards*, CIP-002 through CIP-014.
- US TSA. *Pipeline / Rail Security Directives*, 2021 onwards.
- US CISA. *CIRCA – Cyber Incident Reporting for Critical Infrastructure Act*, in rule-making.
- DOE. *Cybersecurity Capability Maturity Model (C2M2)*, current.

End of Section 09

Standards, Compliance, and Governance

Questions and discussion

